7m 34s 동안 처리함 >

0720특강.mp4
파일

공유하신 파일은 **「0720특강.mp4」**입니다.

0720특강

영상은 약 55분이고, 전반부는 **노인돌봄·시니어 대상 ICT 서비스에서 개인정보를 어떻게 안전하게 수집·활용할 것인가**, 후반부는 질의응답 중심으로 진행됩니다.

핵심 한 문장

> **시니어 돌봄 기술에서 개인정보 보호는 나중에 붙이는 법적 절차가 아니라, 무엇을 수집할지·어떻게 동의를 받을지·어디에 저장할지·AI에 어떻게 보낼지까지 서비스 설계 단계에서 결정해야 하는 핵심 구조다.**

1. 노인돌봄 ICT는 일반 서비스보다 개인정보 위험이 크다

강의는 먼저 노인돌봄 기술의 **'취약성'과 '밀착성'**을 강조합니다.

어르신은 인지적·디지털 이해의 차이 때문에 복잡한 동의 내용을 충분히 이해하지 못한 채 **형식적인 동의**를 할 위험이 있습니다. 동시에 웨어러블, 센서, IoT, 앱 등은 활동·생활패턴·건강 관련 정보를 장시간, 때로는 24시간 가까이 수집할 수 있습니다.

따라서 한 번의 개인정보 유출이 단순한 광고 문제로 끝나는 것이 아니라, 가족관계·건강상태·행동패턴 등이 결합되어 **보이스피싱이나 표적 사기와 같은 2차 피해**로 이어질 수 있다는 것이 핵심 문제의식입니다.

---

2. 모든 데이터를 똑같이 보면 안 된다

강의에서는 데이터를 크게 구분해서 봐야 한다고 설명합니다.

일반 개인정보는 이름, 전화번호, 보호자 연락처, 주소처럼 개인을 식별할 수 있는 정보입니다.

특히 시니어 서비스에서는 다음과 같은 정보가 훨씬 민감합니다.

- 병력
- 인지기능 관련 수치
- 복약 기록
- 치매 관련 상태
- 심박수·혈압과 같은 생체정보
- 활동 및 생활패턴 데이터

- 주민등록번호 등 고유식별정보

즉, 피우다 같은 서비스에서 단순히 `"어르신 A가 오늘 어떤 활동을 했다"`라고 기록하는 것도 기록 방식에 따라 **생활패턴이나 건강·인지상태를 추론할 수 있는 정보**가 될 수 있다는 관점이 중요합니다.

---

3. 실증 전에 가장 먼저 해야 할 것은 “많이 모으는 것”이 아니라 “덜 모으는 것”

강의에서 가장 반복적으로 강조되는 원칙입니다.

최소 수집

> “나중에 분석할 수도 있으니까 일단 다 저장하자”는 접근을 피해야 한다.

예를 들어 정확한 실시간 GPS가 필요하지 않다면 GPS 전체 이동경로를 저장하지 않고, 필요한 **이벤트 단위 정보**만 저장하는 식입니다.

피우다에 적용하면,

`어르신의 하루 전체 행동을 영상·음성·센서로 계속 기록`

보다는

`특정 활동 발생 → 활동 종류 → 참여 여부 → 필요한 최소한의 맥락`

처럼 설계하는 것이 훨씬 적절합니다.

목적을 먼저 정해야 한다

데이터를 받을 때는 **왜 받는지**가 명확해야 합니다.

예를 들어,

> “시설 내 프로그램 참여를 기록하고 서비스 효과를 평가하기 위해 수집”

이라고 동의를 받았는데, 이후 그 데이터를 별도 동의 없이

> “우리 회사 AI 모델 학습용”

으로 사용하는 것은 전혀 다른 목적이 될 수 있다는 점을 강조합니다.

즉,

실증 데이터 = 마음대로 활용 가능한 연구·AI 학습 데이터

가 아닙니다.

보관기간과 삭제 시점을 미리 정한다

“언젠가 필요할 것 같으니 계속 보관”하는 구조도 피해야 합니다.

실증이 끝났을 때 언제 삭제할지, 사용자가 참여를 철회했을 때 어떻게 삭제할지 등을 **실증 전에 정책으로 정해놓아야 한다**는 내용입니다.

---

4. 어르신 동의서는 “서명을 받는 것”보다 “이해시키는 것”이 중요하다

이 부분은 피우다 프로젝트에 특히 중요합니다.

강의에서 강조한 표현은:

> **형식적 서명이 아닌 진정한 ‘이해’**

입니다.

동의서는 법률 문구를 그대로 늘어놓는 것이 아니라,

- 쉬운 한국어 사용
- 중요한 내용만 명확하게 설명
- 충분히 큰 글씨
- 필요한 경우 말로 다시 설명
- 무엇을 수집하는지 구체적으로 설명

하는 방식이어야 합니다.

강의 자료에서는 **14pt 이상의 가독성**도 예시로 제시됩니다.

또한 민감정보는 일반 개인정보와 한데 묶기보다는 **별도로 명확하게 구분해 동의를 받는 구조**가 강조됩니다.

피우다식으로 바꾸면

나쁜 설명:

> “서비스 제공 및 연구 목적을 위하여 개인정보 및 관련 데이터를 수집·처리할 수 있습니다.”

좋은 설명:

> “이 서비스는 어르신이 시설에서 참여한 활동을 기록합니다.”

> “기록되는 내용은 활동 종류, 참여 여부, 기록 시간입니다.”

> “이 정보는 이번 실증 결과를 확인하는 데 사용합니다.”

이런 식으로 **어르신이 실제로 이해할 수 있는 단위로 나누는 것**이 중요하다는 취지입니다.

---

5. 개발자는 개인정보 보호를 “서버에 비밀번호 거는 것” 정도로 보면 안 된다

강의 후반부에서는 꽤 구체적인 기술적 조치를 설명합니다.

① 전송·저장 암호화

앱 ↔ 서버 통신 등에 **TLS/HTTPS**를 기본적으로 적용하고, 저장 데이터 역시 적절히 보호해야 한다는 내용입니다.

② 역할별 접근권한 분리

RBAC(Role-Based Access Control) 방식으로 누가 무엇을 볼 수 있는지 나눠야 합니다.

피우다라면 예를 들어:

- 요양보호사
- 시설 관리자
- 연구자
- 보호자
- 시스템 운영자

가 **모두 같은 정보를 볼 필요는 없습니다.**

요양보호사에게 필요한 정보와 연구자가 필요한 정보, 보호자에게 보여줄 정보는 각각 달라야 합니다.

③ 가명처리·비식별화

통계 분석이나 개발 로그를 만들 때는 이름, 전화번호, 주민번호와 같은 직접 식별정보를 그대로 넣지 않는 것이 중요합니다.

필요에 따라

- 마스킹
- 가명 ID

- 일방향 해시
- 식별정보 분리 저장

등을 적용해야 합니다.

---

6. AI를 붙이는 순간 개인정보 문제가 더 복잡해진다

이 부분은 현재 피우다 프로젝트에서 **LLM·AI 기능을 고려한다면 특히 중요합니다.**

강의에서는 **AI·클라우드·외부 API 사용 시 주의사항**을 별도로 다룹니다.

외부 AI API에 원본 개인정보를 그대로 보내지 않는다

예를 들어 OpenAI나 Kakao 등의 요약·분석 API를 사용한다고 할 때,

> 원본 데이터 → 외부 AI API

로 바로 보내는 구조보다는

> 원본 데이터
> → 개인정보 제거·가명처리
> → 필요한 정보만 추출
> → AI API

구조를 권장하는 취지입니다.

AI 학습 목적과 서비스 이용 목적을 구분한다

특히 강의에서 강조되는 부분은:

> 실증을 위해 받은 데이터를 모델 학습용으로 자동 전환하면 안 된다.

입니다.

예를 들어 어르신이

> “서비스를 이용하기 위해 내 데이터를 사용해도 된다”

고 동의했다고 해서,

> “회사 AI 모델 개선·학습에도 사용해도 된다”

는 의미는 아니라는 것입니다.

클라우드도 최소 권한으로

S3 등 클라우드 저장소를 사용할 경우에도 모든 개발자에게 전체 권한을 주는 것이 아니라 **IAM 최소 권한 원칙**을 적용하는 것을 강조합니다.

---

7. 강의 마지막 체크리스트

영상 마지막의 체크리스트를 압축하면 다음과 같습니다.

수집

민감한 건강정보가 있다면 일반 정보와 구분해 고지·동의했는가?

보관

앱·서버·API 전 구간이 안전하게 보호되고 있는가?

활용

외부 번역·요약·AI API를 사용할 때 주민번호·전화번호 같은 정보가 그대로 노출되지 않는가?

삭제

실증 종료, 참여 철회 등의 상황에서 언제·어떻게 삭제할지 정해져 있는가?

생성형 AI

- 외부 AI 업체가 데이터를 모델 학습에 사용하는지 확인
- 가능하면 학습에 사용하지 않는 기업용 설정 검토
- RAG/지식베이스에 고유식별정보가 들어가지 않게 처리
- 사용자가 대화창에 민감정보를 입력할 가능성에 대비
- AI 학습 활용에 대한 거부·옵트아웃 구조 검토
- 배포 전에 개인정보 관련 위험평가 실시

등이 제시됩니다.

피우다 프로젝트에 대입하면 가장 중요한 5가지

제가 보기에는 이 특강을 피우다에 적용할 때 다음이 핵심입니다.

① “무엇을 기록할 것인가”부터 다시 정의해야 함

피우다가 시설에서 발생하는 어르신의 활동이나 참여를 기록한다면,

원본을 많이 모으고 나중에 AI가 판단하는 구조보다
처음부터 필요한 최소 이벤트만 기록하는 구조가 훨씬 안전합니다.

예:

> `김OO 어르신 / 14:32 / 프로그램 참여 / 종이접기 / 적극적 참여`

보다도 실증 목적에 따라

> `익명 ID 023 / 프로그램 참여 / 참여`

정도로도 충분할 수 있습니다.

즉 **"이 데이터가 정말 우리 가설 검증에 필요한가?"를 항목마다 물어봐야 합니다.**

---

② 특히 "도움을 주었다", "기여했다", "참여했다" 같은 기록도 조심해야 함

이건 매우 중요한 부분입니다.

반복된 데이터를 쌓으면

- 어떤 어르신은 활동을 많이 한다
- 어떤 어르신은 참여가 줄었다
- 어떤 어르신은 특정 행동을 못 한다

등의 패턴이 나타날 수 있습니다.

결국 서비스가 의도하지 않았더라도 **건강상태·인지상태·신체능력 등을 추론할 수 있는 프로파일**이 만들어질 수 있습니다.

따라서 피우다의 "기록"을 단순 활동 데이터라고만 보면 안 됩니다.

---

③ 보호자·시설·연구자 화면의 정보 수준을 다르게 해야 함

모든 이해관계자에게 똑같은 원천 데이터를 보여주는 것보다,

필요한 사람에게 필요한 정보만 보여주는 구조가 좋습니다.

예를 들어 보호자에게는

> "이번 주 활동 참여 4회"

정도만 보여주고,

연구자에게는

> 익명화된 집단 통계

를 제공하는 식입니다.

---

④ 실증 전에 데이터 흐름도를 하나 만들어야 함

이 강의를 보고 가장 먼저 만들 가치가 있는 문서는 이것입니다.

> **어르신 → 키오스크/앱 → 서버 → AI → 관리자 화면 → 연구 분석 → 삭제**

각 단계마다:

무슨 데이터가 들어가는가 → 누가 볼 수 있는가 → 어디에 저장되는가 → 외부로 나가는가 → 언제 삭제되는가

를 한 장으로 그려야 합니다.

이걸 만들면 개인정보 동의서, 기술 아키텍처, 실증 프로토콜이 거의 동시에 정리됩니다.

---

⑤ 일본 실증에서는 이 강의 내용을 그대로 법적 기준으로 쓰면 안 됨

이 특강은 기본적으로 **한국 개인정보보호법 관점의 설명이 중심**입니다.

피우다가 일본에서 실증한다면 여기서 배운 **최소수집·목적명확화·쉬운 동의·접근권한 분리·AI 외부전송 통제**라는 설계 원칙은 그대로 가져가되, 실제 동의 방식과 시설의 법적 책임, 건강·요양정보 처리, 해외 클라우드 전송 등은 **일본 개인정보보호법(APPI)과 일본 시설 실무 기준에 맞춰 별도로 검증**해야 합니다.

참고로 영상은 약 **33분 전후까지 강의자료 중심**, 이후는 질의응답 중심이라, 위 내용은 화면에 제시된 강의자료와 확인 가능한 강의 구조를 중심으로 정리했습니다. 후반 질의응답의 개별 발언까지 정확한 속기 형태로 옮긴 요약은 아닙니다.